



Building AI-Native DevSecOps Platforms with Governed Platform Engineering

A practical reference architecture unifying security, automation, and observability so your organization adopts AI without sacrificing reliability or operational control.

PLATFORM ENGINEERING · DEVSECOPS · AI GOVERNANCE

Presented by Sonu Kumar

Affiliation: Peoplefluent

The Challenge

Two Mandates. One Platform.



Platform teams today face a dual imperative that pulls in opposite directions:

The organizations that master both will define the next generation of software delivery.

Build for AI

Provision secure infrastructure that supports RAG pipelines, inference services, agents, and model lifecycle management.

Build with AI

Embed AI into DevSecOps workflows to accelerate delivery, harden security posture, and sharpen operational intelligence.



The Reference Architecture

A unified platform that governs AI workloads and traditional cloud-native services under a single, observable control plane, with policy, automation, and auditability woven throughout every layer.

Five Layers of a Governed AI-Native Platform

5 Governance & Observability

Policy-as-code, audit, metrics, traces — every layer

4 DevSecOps Automation

CI/CD, supply-chain security, GitOps delivery, governed agents

3 AI Workload Layer

RAG pipelines, inference serving, agents, model lifecycle

2 Platform Services

Identity, secrets, artifact & model registry, service mesh

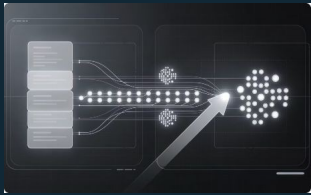
1 Infrastructure Foundation

Compute & GPU pools, storage, networking, Kubernetes

Each layer is independently operable yet tightly integrated. Governance and observability span the entire stack, not just the edges.

AI Workload Support

What the Platform Must Serve



Retrieval-Augmented Generation

Vector stores, chunking pipelines, and embedding services alongside strict data lineage controls.



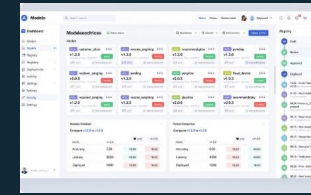
Inference Services

Scalable, autoscaled model serving with latency SLOs, cost guardrails, and hardware-aware scheduling.



Intelligent Agents

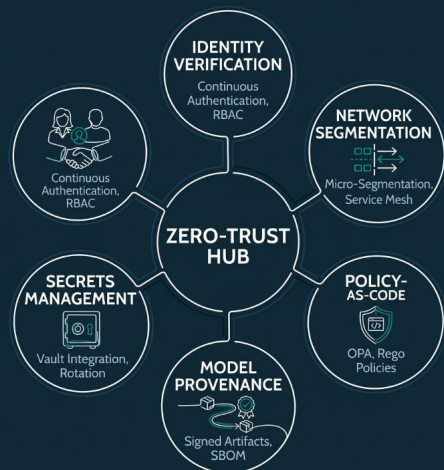
Governed agentic workflows with defined tool permissions, approval gates, and execution audit trails.



Model Lifecycle

Registry, versioning, provenance tracking, and automated promotion pipelines from experiment to production.

Zero-Trust Meets Policy-as-Code



Every workload - AI or traditional - operates under the same zero-trust posture. No implicit trust; every request is verified, authorized, and logged.

1

Policy-as-Code

OPA and Rego enforce admission, runtime, and data access policies declaratively - version-controlled alongside application code.

2

Model Provenance

Cryptographically signed model artifacts with full SBOM traceability from training data to production deployment.

3

RBAC at Every Layer

Granular role bindings govern who can deploy, invoke, retrain, or override any AI or infrastructure component.



Observability Is Not Optional

In AI-native platforms, observability extends beyond latency and error rates. **Model drift, token costs, agent decision paths, and policy violation rates** are first-class signals that feed your control plane.

Continuous Observability

What You Must Measure

Infrastructure Signals

CPU, GPU utilization, pod health, queue depth, and network throughput across all workload types.

AI-Specific Metrics

Inference latency, token consumption, embedding quality, model drift scores, and hallucination rate proxies.

Security Telemetry

Policy violation events, anomalous RBAC access patterns, and real-time audit logs for every privileged action.

Agent Traces

Full execution traces for agentic workflows, including tool calls, intermediate reasoning steps, and human-in-the-loop handoffs.

Automation With a Safety Net



Governed agents extend DevSecOps automation beyond scripts and pipelines - but they **must not operate without constraints**.

- **Deployment validation:** Agents verify rollout health against SLOs before cutover.
- **Incident triage:** Automated root-cause scoping with escalation when confidence is low.
- **Self-healing:** Policy-bounded remediation - no action taken outside approved playbooks.
- **Compliance checks:** Continuous drift detection with gated rollback authority.

Human Oversight

Approval Gates Are Architecture, Not Bureaucracy

Why Gates Matter

Autonomous systems that can self-heal, redeploy, or modify infrastructure must have defined boundaries. Approval gates encode those boundaries as enforceable policy, not informal convention.

O1

Define Autonomy Tiers

Classify actions by blast radius: auto-approved, human-notified, or human-required.

O3

Log Every Decision

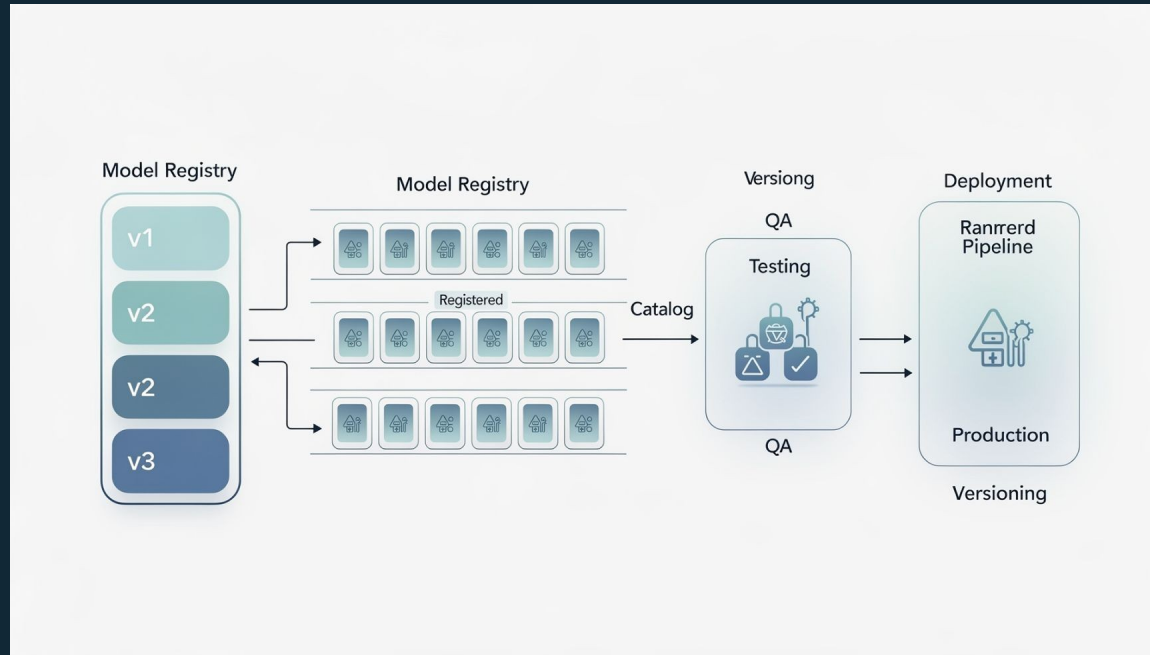
Every agent action - approved or blocked - writes an immutable audit record with context and actor identity.

O2

Encode as Policy

Gate conditions live in version-controlled policy files - auditable and PR-reviewed like application code.

Model Lifecycle Management at Scale



Model lifecycle management is a platform engineering responsibility, not a data science afterthought. Production readiness requires:

→ Registry-First Promotion

No model reaches staging or production without a signed, validated registry entry with provenance metadata.

→ Canary + Shadow Serving

Gradual traffic shifting with automated rollback triggers tied to latency, accuracy, and business KPIs.

→ Drift-Triggered Retraining

Observability signals feed automated retraining pipelines, keeping models aligned with production distributions.

Real-World Lessons

What Production Actually Teaches You



Governance Debt Compounds Fast

Every ungoverned AI component added to production multiplies audit surface area and incident blast radius.



Platform Abstractions Save Teams

Golden paths for AI workloads - standardized templates, sidecar policies, and pre-wired observability - cut onboarding from weeks to days.



Shared Ownership Is Non-Negotiable

Security, platform, and ML engineering must co-author standards - siloed ownership produces dangerous gaps.



A Case From Production

The Agent Was Right. The Gate Was Too.

21:40

Canary starts

New generation-model version for a RAG assistant rolls to 10% of traffic via GitOps.

+6 min

Signals fire

Canary p99 latency 380 ms → 2.1 s; GPU memory at 96%; two inference pods OOMKilled.

+8 min

Agent triages

Correlates metrics, logs and rollout history. Confidence high: the new version is the cause.

+9 min

Tier 1: auto-approved

Abort canary and roll back. Scoped, reversible, inside the playbook. Latency recovers.

+10 min

Tier 3: blocked

Agent proposes draining 3 shared GPU nodes. Policy denies; on-call is paged with the evidence.

9 min

from first signal to rollback

0

errors outside the 10% canary

1

unsafe action blocked by policy before it ran

Fix: admission policy now rejects any model deployment whose resource requests are below its registry profile.

Composite scenario drawn from production patterns; details anonymised.

Balancing the Equation

Innovation vs. Operational Safety



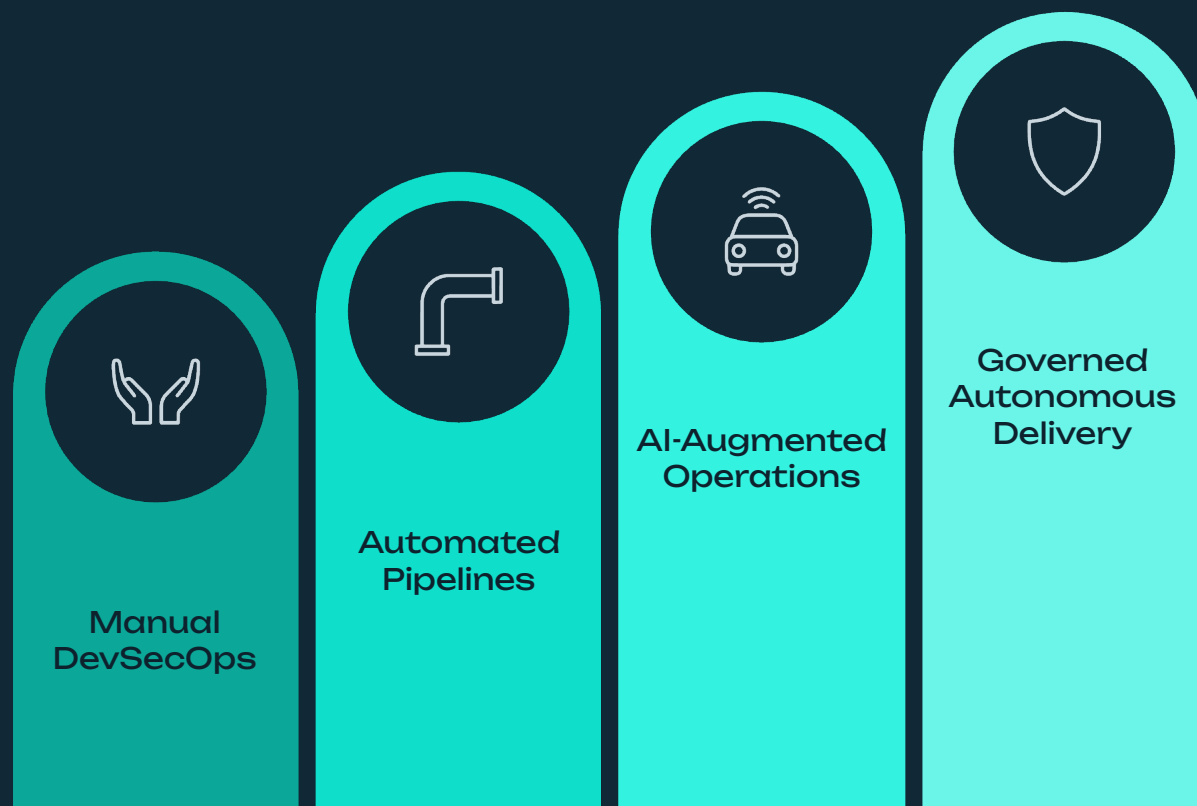
The tension between moving fast and staying safe is real - but it's a **solvable engineering problem**, not a cultural standoff.

Governance done well **accelerates delivery** by reducing ambiguity, automating compliance checks, and giving teams pre-approved patterns to build on. The goal is not to slow down AI adoption - it's to make velocity *sustainable*.

- Teams with mature policy-as-code practices ship AI features faster, not slower - because they spend less time on incident recovery and audit remediation.

The Path Forward

Preparing for Autonomous Software Delivery



The next generation of software delivery is autonomous - but autonomy without governance is just uncontrolled risk. Start building your governance foundation now, before the agents arrive at scale.



Key Takeaways

1 Unify both mandates

Build *for* AI and *with* AI on a single governed platform, not two separate efforts.

2 Policy-as-code is foundational

Zero-trust, RBAC, provenance, and auditability must be woven into the platform, not bolted on post-deployment.

3 Observability spans all layers

From infrastructure to model drift to agent traces - if you can't measure it, you can't govern it.

4 Approval gates enable, not block

Human oversight encoded as policy gives agents a clear operational envelope - and gives your org confidence to expand it.

Thank You